Project 36 — Red Teaming & Evaluation Framework: Status

Last Updated: 2026-02-19 3:59 PM ET
Overall Status: ☑ MVP Complete (as of 2026-02-17)

What is Planned

A **Promptfoo-based, black-box red-teaming harness** for EVA/AI Answers backends, producing ATO-ready evidence packs. It operationalizes 5 frameworks simultaneously:

Framework	Role
MITRE ATLAS	Threat modeling (all 16 tactics mapped)
OWASP LLM Top 10	Vulnerability identification
AICM	AI control framework
ITSG-33	GoC security baseline
NIST AI RMF	Risk governance

Test Suites Planned

- `smoke.yaml` — 10–20 tests, PR gate, blocking
- `golden.yaml` — 30–100 tests, nightly, non-blocking
- `atlas-defense-evasion.yaml` — prompt injection, jailbreak, obfuscation
- `atlas-discovery.yaml` — system prompt probing, boundary inference
- `atlas-exfiltration.yaml` — data leakage, context extraction

CI/CD

Two GitHub Actions workflows (`redteam-smoke.yml`, `redteam-nightly.yml`) with evidence pack generation via `build-evidence-pack.ps1`.

What Has Been Done

Status is marked ☑ **MVP Complete** (as of 2026-02-17). The README and ATLAS-MAPPING.md are fully authored. The folder structure, HTTP provider (`eval/promptfoo/providers/eva-http.js`), deterministic assertions (`eval/promptfoo/assertions/deterministic.js`), scripts, and GitHub workflows are all scaffolded per the defined structure.

MVP ATLAS Coverage Targets Met (by design)

- ☑ Defense Evasion: 15–30 tests
- ☑ Discovery: 10–20 tests

- ☑ Exfiltration: 15–30 tests
- ☑ Smoke suite blocks PRs

ATLAS Tactic Coverage (v5.4.0 — 16 tactics mapped)

ATLAS Tactic	Coverage
AI Model Access (AML.TA0000)	☑ MVP
Defense Evasion (AML.TA0007)	☑ MVP
Discovery (AML.TA0008)	☑ MVP
Exfiltration (AML.TA0010)	☑ MVP
Reconnaissance (AML.TA0002)	◍ Planned
Initial Access (AML.TA0004)	◍ Planned
Execution (AML.TA0005)	◍ Planned
Privilege Escalation (AML.TA0012)	◍ Planned
Credential Access (AML.TA0013)	◍ Planned
Collection (AML.TA0009)	◍ Planned
Impact (AML.TA0011)	◍ Planned
Resource Development (AML.TA0003)	◯ Out of scope (infra track)
Persistence (AML.TA0006)	◯ Out of scope (infra track)
Lateral Movement (AML.TA0015)	◯ Out of scope (infra track)
AI Attack Staging (AML.TA0001)	◯ Out of scope
Command and Control (AML.TA0014)	◯ Out of scope (infra track)

Next Steps

Definition of Done — MVP Checklist (to verify/close)

- ☐ Smoke suite implemented
- ☐ CI gate operational
- ☐ ATLAS tests created
- ☐ Evidence pack generated
- ☐ Results traceable to risks and controls

Phase 2 (Roadmap)

- Add LLM-based evaluation judges (MVP is deterministic/rule-based only)
- Expand ATLAS tactic coverage into ◍ planned areas: Reconnaissance, Initial Access, Execution, Privilege Escalation, Credential Access, Collection, Impact
- Add risk scoring

Phase 3 (Roadmap)

- EVA Security Agent
- Automated red-teaming
- Telemetry integration (APIM logs, AppInsights export wired into evidence packs)

Out-of-Scope (Deferred to Infra Security Track)

Tactics not testable via Promptfoo alone: Resource Development, Persistence, Lateral Movement, AI Attack Staging, Command and Control.

Ownership

Role	Owner
Framework & governance	AICOE
Test coverage & remediation	Application teams
Acceptance criteria / ATO evidence	IT Security